



Class 15 — Topic 5: Detecting and Diagnosing Anomalies

- 420-1C1-DW Preventative Monitoring — LEA.D8 (AEC)
- Saturday, October 10, 2026 · 2:00 – 6:00 pm · online
- 5.1 What an anomaly (unusual activity) is
- 5.2 Reviewing and sorting alerts (triage)
- Quiz 3 (5 %) today — covers Topics 3 and 4
- Cyber.SoHo Educational Hub — From the Industry to the Classroom

Legal notice, terms of use and acceptable use

- Every exercise runs in the authorised lab, on the fictional Atelier Nordik network
- Monitoring data is confidential: Legal Notice sections 6.7, 7.2 and 17
- Never point monitoring at a person; never capture on a shared network
- Criminal Code s. 342.1 and s. 184 · US 18 U.S.C. § 1030 (CFAA) · EU Directive 2013/40/EU · Spain Ley Orgánica 10/1995
- Full text: cyber-soho.github.io/prevmon — Legal Notice v2.0 (link in the module)



Where we are, and the plan for today

- Topic 3: tools, baseline, alerts (Lab 2) → Topic 4: logs, traffic, files, filtering → Topic 5: detect and diagnose
- 0:00 – 0:30 Lesson 5.1 — anomaly: definition, families, detectors, outcomes, Example 5.1
- 0:30 – 1:00 Lesson 5.2 — alerts, triage, scales, queue, Example 5.2
- Then: Lab 3 preview, downloads, Quiz 3
- Thursday October 15: 5.3 analysis, 5.4 diagnosis, 5.5 communication, Quiz 4
- Friday October 16: Topic 6 and Lab 3



Learning outcomes and competency EZ01, element 4

- Define anomaly, baseline, tolerance, deviation; distinguish anomaly, incident, attack, false alarm
- Classify an anomaly as point, contextual or collective
- Explain five detection methods and compute a z-score
- Name the four outcomes of a detector (TP, FP, FN, TN)
- Define triage; apply the five questions; score impact and confidence
- Produce an ordered, justified alert queue
- Performance criteria: 4.2 methodical analysis, effective detection; 4.5 accurate diagnosis (prepared)



The scenario: Atelier Nordik inc. (fictional)

- 14-person industrial-design firm, Mile-End, Montréal — the Lab 1 network
- OPNsense firewall and VPN (pool 10.8.0.0/24)
- LAN 192.168.10.0/24: SRV-AD01 (.5, AD DS + files), MON-250 (.250, monitoring), workstations .20–.60 (WS-10-44, WS-10-31)
- DMZ 192.168.20.0/24: srv-web01 (.10, public web)
- Accounts: ldube, jtremblay, ops, backup-svc, administrator
- External (RFC 5737): 203.0.113.57, 203.0.113.80, 198.51.100.200



Lesson 5.1 — What an anomaly (unusual activity) is

- 5.1.1 Event, log record, baseline, anomaly
- 5.1.2 Unusual is not malicious
- 5.1.3 Point, contextual, collective
- 5.1.4 Where anomalies show up
- 5.1.5 How a detector decides
- 5.1.6 The four outcomes
- 5.1.7 Benign causes; performance versus security
- Videos · Example 5.1 · flash cards · check-in



5.1.1 Four words that must stay separate

- Event — a single observable occurrence (a logon, a connection, a file write)
- Log record — the written trace of an event, with its fields
- Baseline — the statistical description of normal activity, per scope and per context
- Anomaly — an observation that deviates from the baseline beyond a tolerance
- Three parts of the definition: reference · measure of deviation · threshold
- "Unusual activity" says nothing about intent — the cause is found in diagnosis (5.4)



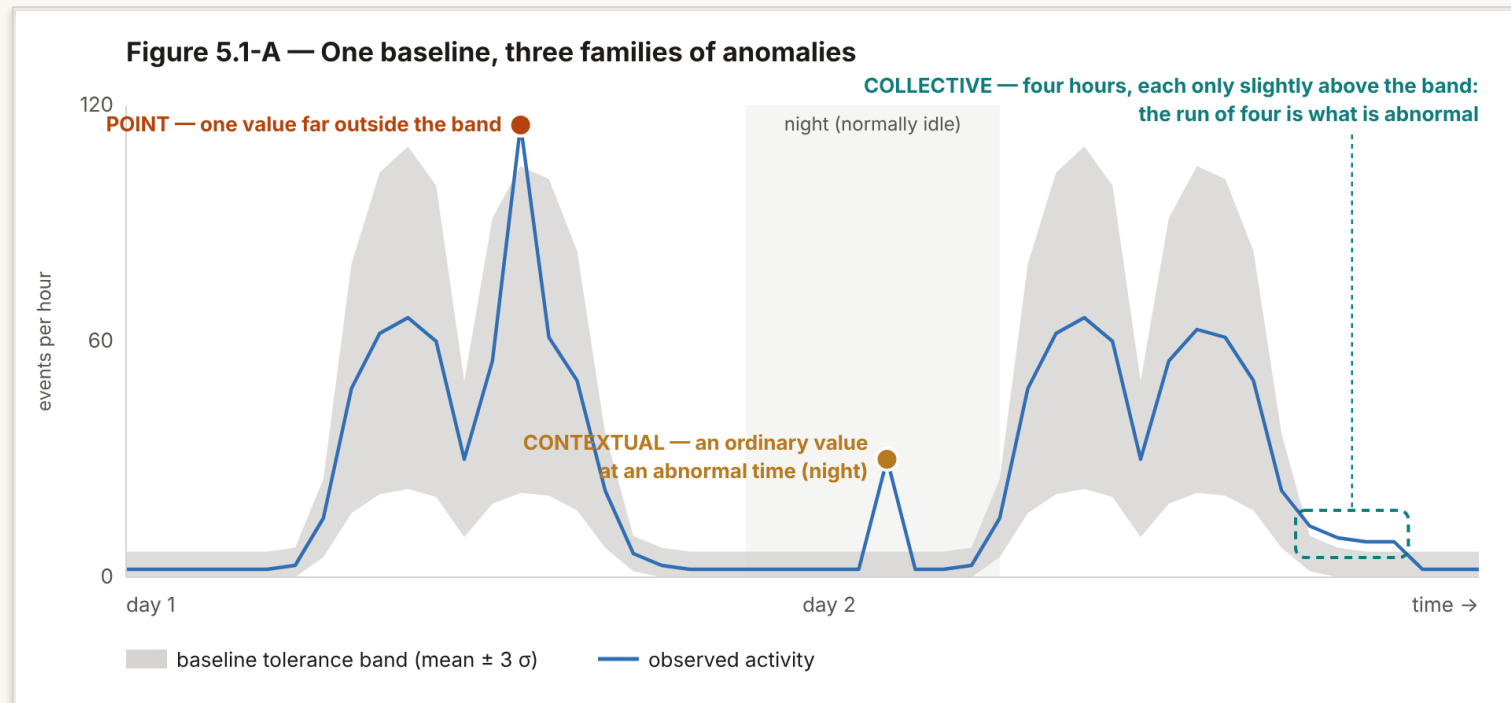
5.1.2 Unusual is not malicious

- Anomaly: a measured deviation
- Security incident: an anomaly caused by a violation of policy (CIA)
- Attack: a deliberate attempt; incidents also come from error and failure
- False alarm: an anomaly with a harmless explanation
- Every incident starts as an anomaly; most anomalies are not incidents
- Precursor (may occur) · Indicator (may have occurred) · IoC (specific, shareable)



5.1.3 Three families of anomalies

- Point — one value far outside the band (distance test)
- Contextual — an ordinary value at an abnormal time or place (conditional test)
- Collective — ordinary observations forming an abnormal set or sequence (pattern test)
- One episode can belong to several families; name the one your rule tested



5.1.3 The three families — Atelier Nordik examples

- Point: WS-10-44 opens 112 connections in one hour (baseline 63 ± 15); a 1.2 GB transfer from a server that never sends 50 MB
- Contextual: 47 connections at 19:00 Thursday (baseline 3 ± 1.5); a VPN logon by backup-svc
- Collective: 23 SSH failures on 7 names in 4 minutes; 16 ports of srv-web01 in 42 seconds
- Class 14 rules were collective detectors: counts in a window
- Example 5.1 is a point and contextual detector: a z-score per hour of the day



5.1.4 Where anomalies show up: the three data sources

- Event logs: logons per account, failures per source, service starts
- Network traffic: connections per host per hour, bytes out, destinations
- Network files and system activity: processes, files, configurations, scheduled tasks
- The same cause often appears in two sources (auth.log and firewall log)
- Corroboration: the same anomaly from two independent sources raises confidence
- Table 5.1-2 gives a normal value and one anomaly of each family per source



5.1.5 How a detector decides "unusual" (1/2)

- Detector: the rule or component that turns records into "unusual" / "normal"
- Signature-based: compares with known bad patterns — precise, blind to new threats
- Threshold-based: a count in a window against a fixed number — simple, transparent
- Both Class 14 scripts are threshold detectors (≥ 10 in 10 min; ≥ 10 ports in 60 s)
- NIST SP 800-94 is the reference for these definitions



5.1.5 How a detector decides "unusual" (2/2)

- Statistical: mean and standard deviation (σ) of the baseline $\rightarrow$ z-score
- $z = (\text{observed} - \text{mean}) / \sigma$; common tolerance $|z| \geq 3$
- Behavioural: one profile per host / user / service, per context (UEBA)
- Machine-learning: a learned model of normal; powerful, hard to explain (not used here)
- Rule 1: a statistical test needs a long, clean baseline
- Rule 2: add a minimum absolute difference — a tiny baseline makes small changes look extreme



The z-score, step by step

- Baseline of WS-10-44 at 19:00 (workdays): mean 3, σ 1.5
- Observed Thursday 19:00: 47 connections
- $z = (47 - 3) / 1.5 = 29.3 \rightarrow$ far beyond 3 $\rightarrow$ flagged
- Friday 10:00: observed 98, baseline $66 \pm 15 \rightarrow z = 2.13 \rightarrow$ inside tolerance, not flagged
- Tuesday 03:00: observed 6, baseline $2 \pm 1.2 \rightarrow z = 3.3$ but difference $4 < 10 \rightarrow$ guard applies, not flagged
- Two conditions: $|z| \geq 3$ AND $|\text{observed} - \text{mean}| \geq 10$



5.1.6 The four outcomes of a detector

- True positive (TP): flagged and unwanted — the SSH burst
- False positive (FP): flagged and harmless — the Patch-Wednesday hour (a benign true positive when the rule worked on authorised activity)
- False negative (FN): unwanted and not flagged — only found by another detector or later
- True negative (TN): nothing happened, nothing flagged
- Base-rate effect: $10,000 \text{ records/day} \times 1 \% \text{ FP} = \text{about } 100 \text{ false alarms a day}$
- Trade-off: lower threshold $\rightarrow$ more TP and more FP; higher $\rightarrow$ the reverse (Topic 6.4)



5.1.7 Benign causes; security versus performance

- Scheduled jobs: backups, update pushes, definition downloads, month-end reports
- Changes: new software, new employee, new printer, a firewall rule added by the contractor
- Calendar: holidays (Thanksgiving Monday), daylight-saving change on November 1 shifts every hourly baseline
- Failures: full disk, expired certificate, service restart loop; people: late work, repeated typos
- Document them in the maintenance calendar and the allow-list before the alert arrives
- Performance anomaly and security anomaly look alike at detection; they differ at diagnosis — both must reach a human



Videos for lesson 5.1 (verified, ≤ 15 min)

- Professor Messer — Indicators of Compromise (SY0-701, 2.4) — 10:59 — youtube.com/watch?v=x72hG9GvkaQ
→ lockouts, concurrent sessions, impossible travel, resource consumption, missing logs
- Professor Messer — Security Monitoring (SY0-701, 4.4) — 10:27 — youtube.com/watch?v=np2WI_rM-Ok
→ continuous monitoring, SIEM correlation, alerts, tuning false positives and negatives
- Both verified on October 10, 2026 (title, channel, duration)



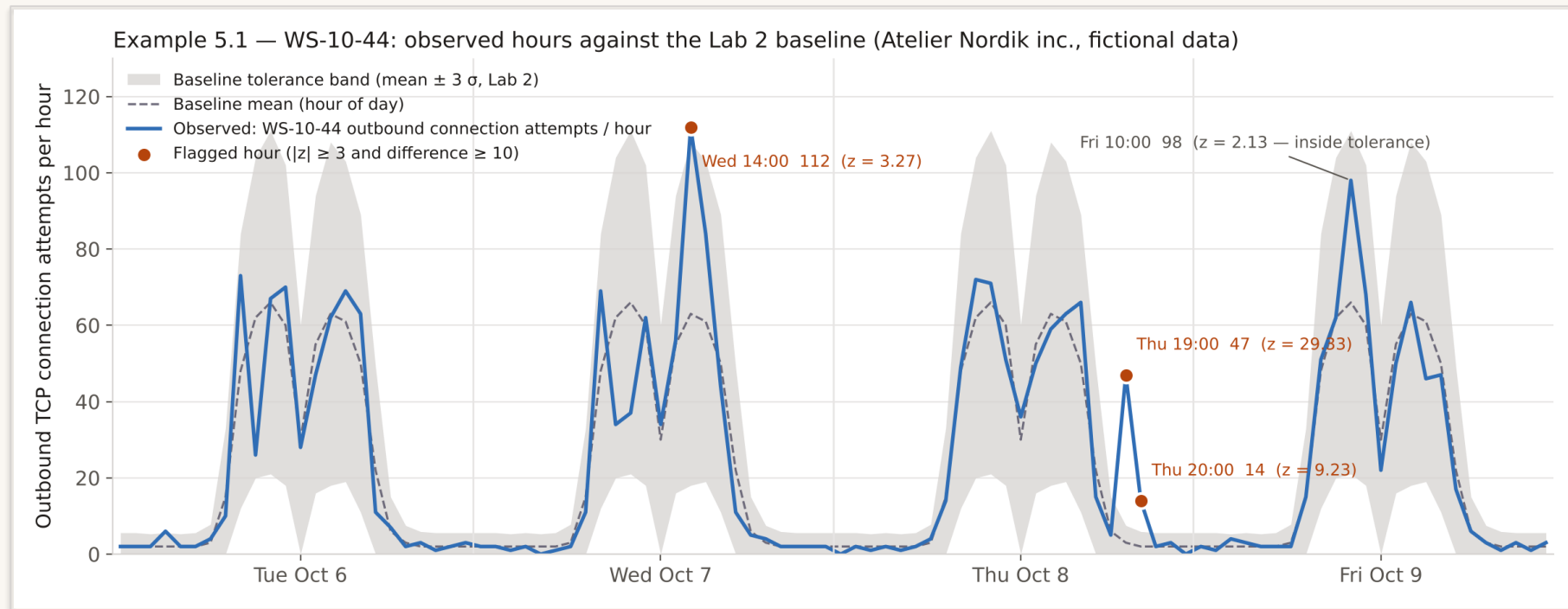
Example 5.1 — The designer workstation that woke up at night (1/3)

- Task: compare 4 observed days of WS-10-44 (outbound connection attempts per hour) with the Lab 2 hourly baseline
- Flag the hours beyond tolerance; name the family of each flag
- Method: z-score per hour of the day (statistical + behavioural)
- Rule: $|z| \geq 3$ AND difference ≥ 10 ; runs of flagged hours $\rightarrow$ collective
- Files: baseline_hourly.csv, observed_week.csv $\rightarrow$ anomalies.csv
- Lab 3: the output file and the chart are the "detect" input



Example 5.1 — Results (2/3)

- Wed 14:00 — 112 (z 3.27) — point — Patch Wednesday: benign, documented
- Thu 19:00 — 47 (z 29.3) and Thu 20:00 — 14 (z 9.2) — contextual + collective
- Fri 10:00 — 98 (z 2.13) — elevated, inside tolerance
- Tue 03:00 — 6 (z 3.3, difference 4) — guard applied



Example 5.1 — The script and what goes to Lab 3 (3/3)

- `baseline_deviation.py`: load baseline → load observations → z-score → evaluate (two conditions) → mark runs → write CSV → print flags
- A comment line explains every line of code; the simulator in the module replays it hour by hour
- Two detectors now point at WS-10-44 on Thursday evening: corroborated
- Open for Lab 3: which process on WS-10-44; was the designer present; what is 198.51.100.200
- Deliverable: `anomalies.csv` with the family named for every flagged hour



Check-in 5.1 — flash cards and questions

- Five flash cards: definition parts · families · z-score · precursor vs indicator · base-rate effect
- Four MCQ and two MSQ in the module, each with a hint and an explanation per option
- Expected time: 6 minutes
- Then a 3-minute break before lesson 5.2



Lesson 5.2 — Reviewing and sorting alerts (triage)

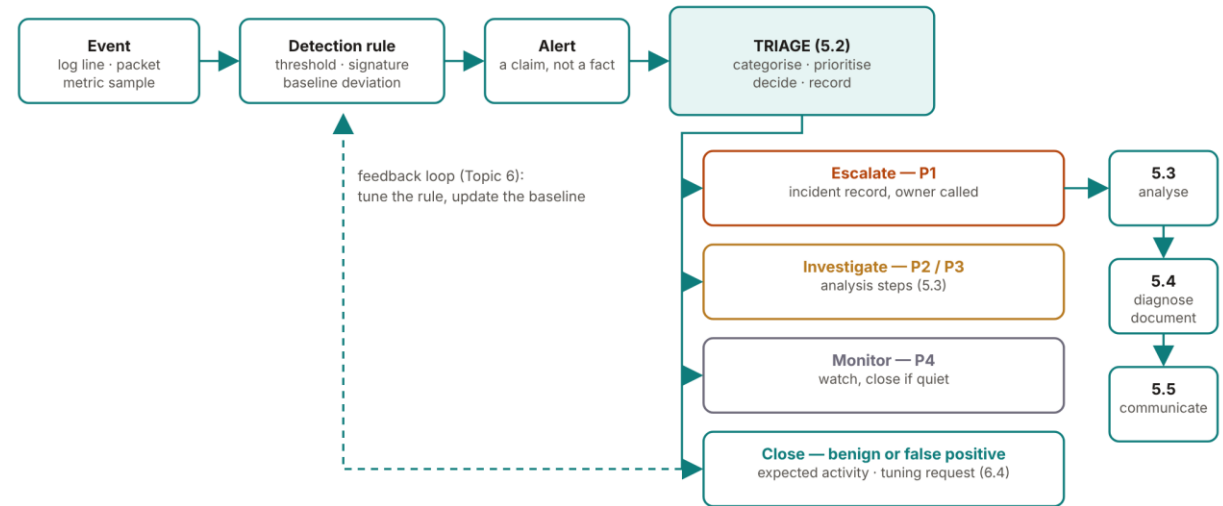
- 5.2.1 From anomaly to alert
- 5.2.2 Triage: the definition and the three verbs
- 5.2.3 The five triage questions
- 5.2.4 Categorising the outcome
- 5.2.5 Severity, impact, confidence, priority
- 5.2.6 Aggregation, correlation, known-good lists
- 5.2.7 Recording the decision
- 5.2.8 Alert fatigue and the six mistakes
- Videos · Example 5.2 · flash cards · check-in



5.2.1 From anomaly to alert

- Alert = "rule X matched record Y at time Z" — a claim, not a fact
- Carries: rule, time, source, asset, account, addresses, a severity, the records
- Verification in two stages: triage (short) and analysis (long, 5.3)
- Triage routes; it does not investigate — time box of 5 to 15 minutes per alert
- Feedback path: benign and false alerts return to the rules and the baseline (Topic 6)

Figure 5.2-A — From an event to a decision: where triage sits



Every box on the right is a Lab 3 deliverable: the queue (5.2), the analysis (5.3), the diagnosis (5.4), the report (5.5).

5.2.2 Triage: definition and the three verbs

- FIRST CSIRT Services Framework: categorise, prioritise, produce an initial assessment
- NIST SP 800-61: inside "detection and analysis"; prioritisation is the critical decision
- 1. Categorise — what kind of alert, what kind of outcome
- 2. Prioritise — impact × confidence → position in the queue
- 3. Decide and record — escalate / investigate / monitor / close, with the reason
- At Atelier Nordik: technician = level 1, IT contractor = level 2, owner = the person to call



5.2.3 The five triage questions

- What fired? rule, data source, window, threshold (count rule ≠ informational rule ≠ absence rule)
- Where? asset, zone, criticality, owner
- Who? account and role — privileged accounts raise the impact
- When? time, duration, still going on? inside a maintenance window? (one time zone)
- How sure? records, independent sources, allow-list, corroboration, possible rule error
- The answers are the "initial assessment" and feed the two scales



5.2.4 Categorising the outcome

- True positive — unwanted: stays open, prioritised
- Benign true positive — expected: closed with the document that explains it (calendar, allow-list, contract)
- False positive — rule error: closed, rule sent for correction
- Duplicate: merged; count and "recurring" mark — recurrence raises confidence
- Undetermined — needs information: kept open with a watch action and a date
- Benign TP → update baseline/allow-list; FP → fix the rule (Topic 6)



5.2.5 Severity is not priority

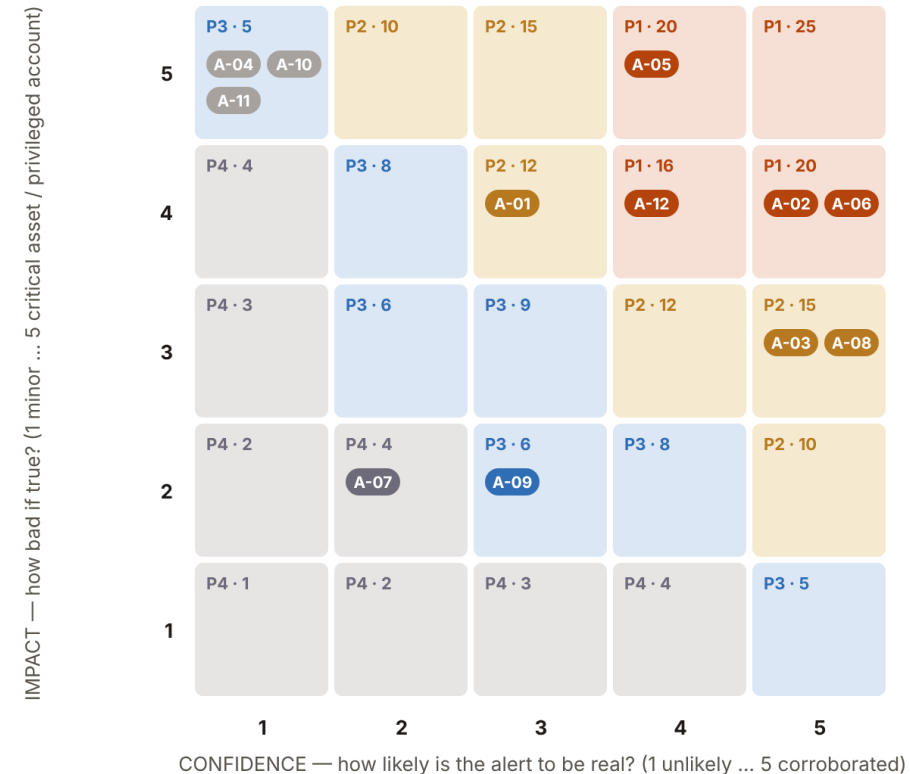
- Severity: attached to the rule by its author, before any context
- Priority: the order of work, computed in triage for this alert on this asset
- Impact (1–5): how bad if true — NIST: functional impact, information impact, recoverability
- Practical scale: $\max(\text{rule severity}, \text{asset criticality})$, +1 for a privileged account, cap 5
- Confidence (1–5): how likely to be real — start 3; +1 unexplained external address; +1 corroborating open alert; –1 informational rule; forced to 1 when explained



5.2.5 Priority = impact × confidence

- P1 Critical 16–25: acknowledge in 15 min, incident record, call owner and contractor
- P2 High 10–15: investigate today
- P3 Medium 5–9: this week, Monday review
- P4 Low 1–4: monitor, close if quiet for 7 days
- Hand adjustments: activity still in progress → up one band; monitoring health alerts never below P2
- Why multiply? only "serious AND credible" reaches the top

Figure 5.2-B — Priority matrix: impact × confidence, with the 12 weekend alerts



Bands: P1 ≥ 16 escalate now · P2 10–15 today · P3 5–9 this week · P4 ≤ 4 monitor.

Grey chips = benign, expected activity (confidence forced to 1, closed with the documented reason).



5.2.6 Aggregation, correlation, known-good lists

- Aggregation: 23 SSH failures = one alert with a count (group by rule, asset, source, 60 min)
- Correlation: alerts sharing an entity tell one story (A-02, A-03, A-08 on WS-10-44)
- Allow-list: addresses, accounts, patterns documented as legitimate, with the proof
- Maintenance calendar: window with asset, activity, responsible person
- Pitfall: match a window on asset, time AND activity
- Matched on asset and time only, the backup window would have closed A-05 (administrator guessing at 02:40)



5.2.7 Recording the decision

- A decision that is not written down does not exist
- Fields: identifier, time (UTC + local), source, rule, asset, account, addresses
- Category, outcome, impact, confidence, priority, justification
- Decision, next step, responsible person, due date, status
- Pointers to evidence — raw, unmodified; time of review; reviewer
- Monitoring data is confidential (Legal Notice 6.7, 7.2, 17; privacy law in 8.3)



5.2.8 Alert fatigue and the six common mistakes

- Alert fatigue: more alerts than attention → alerts closed unread, the real one with them
- 1. Ordering by rule severity alone
- 2. Handling the newest first (priority, then age)
- 3. Closing without a reason
- 4. Ignoring health alerts (full disk, silent source)
- 5. Treating a quiet queue as a safe network (false negatives)
- 6. Over-broad known-good rules (name the activity excused)



Videos for lesson 5.2

- Professor Messer — Incident Response (SY0-701, 4.8) — 9:14 — youtube.com/watch?v=X2UiMLxRdhE
 - preparation, detection through alerts and logs, analysis, containment, recovery, lessons learned
- Optional: MyDFIR — SOC Alert Triage Explained: What Most Beginners Get Wrong — youtube.com/watch?v=k9c1PBynVpA
 - an analyst's reasoning in front of a queue (length not published on a readable page: watch the first 15 minutes)
- Both reachable on October 10, 2026



Example 5.2 — Saturday 14:00: twelve alerts in the weekend queue (1/3)

- Task: triage the 12 alerts of Fri 18:00 → Sat 13:00 on MON-250
- Remove explained alerts (calendar, allow-list); score impact and confidence; compute priority; decide; record
- Inputs: alerts_weekend.csv, assets.csv, allowlist.csv, maintenance_calendar.csv → triage_queue.csv
- Four alerts known from Class 14 (scan, SYN to 4444, administrator burst, SSH burst), eight new
- Lab 3: the queue is the "sort" deliverable and the start of "diagnose"



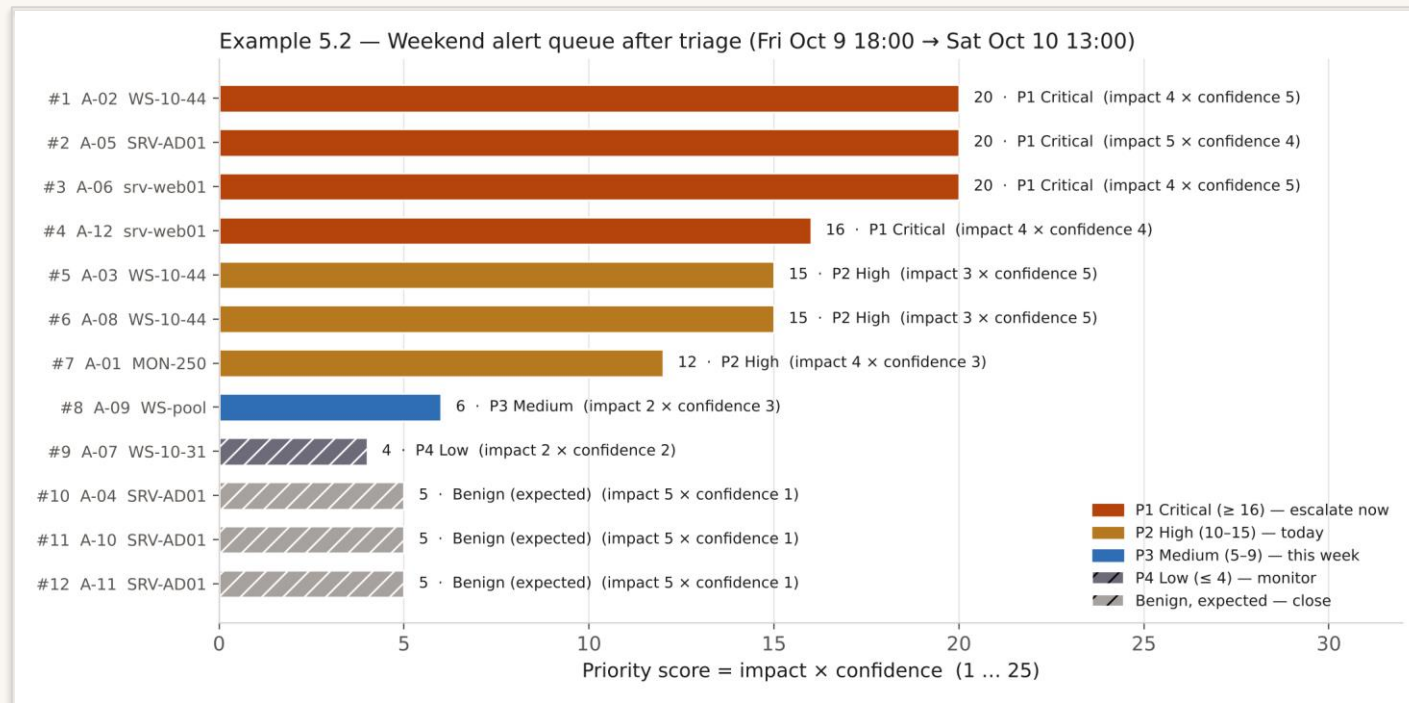
Example 5.2 — Scoring walk-through (2/3)

- Pass 1 — explained: A-04 backup window (backup-svc) · A-10 Idube VPN address + "3 failures then success" · A-11 vendor mirror window
- A-02 scan: impact $\max(4, 2) = 4$; confidence $3 + 1$ (unexplained destination) + 1 (A-03, A-08 same host) = 5 → 20 P1
- A-05 administrator burst: impact $\max(4, 5) + 1$ privileged = 5; confidence $3 + 1$ (unknown VPN address) = 4 → 20 P1
- A-06 SSH burst: impact 4; confidence $3 + 1$ (Internet source) + 1 (A-12 same server) = 5 → 20 P1
- A-12 silent log source: impact $\max(3, 4) = 4$; confidence $3 + 1$ (A-06) = 4 → 16 P1
- A-01 disk 86 %: impact $\max(2, 4) = 4$; confidence 3 → 12 P2 (health: never below P2)



Example 5.2 — The resulting queue (3/3)

- P1: A-02, A-05, A-06, A-12 · P2: A-03, A-08, A-01 · P3: A-09 · P4: A-07 · Benign: A-04, A-10, A-11
- Read it as a story: a probing workstation; VPN guessing on the domain controller; Internet guessing on the web server, which then went silent; the monitoring disk filling
- Equal scores: oldest first (A-02 before A-06) — the technician may move items with a written reason
- Deliverable: triage_queue.csv with a reason on every line



Check-in 5.2 — flash cards and questions

- Five flash cards: three verbs · severity vs priority · confidence rule · the calendar pitfall · health alerts
- Four MCQ and two MSQ with hints and explanations
- Expected time: 6 minutes



Lab 3 — Integrative Project, Part 3 (Friday October 16) — summary only

- Detect: run the Class 14 scripts and baseline_deviation.py; hand in the three summary files with the family of each flag
- Sort: run alert_triage.py; hand in triage_queue.csv; justify any position changed by hand
- Diagnose (5.3, 5.4): two P1 items; answer the open questions; diagnosis sheet
- Report (5.5): one page for the owner, a technical annex for the contractor
- Optimise (Topic 6): a baseline update, a tuning change, a coverage improvement
- Lab 3 is published separately; keep today's downloaded files



Quiz 3 (5 %) — today

- Covers all material of Topic 3 and Topic 4 — nothing from today
- Online, individual, at the end of the class; ISEP rules apply (no electronic dictionaries, no telephones)
- 60 % is the passing grade of every assessment
- Review the Class 11–14 modules and their flash cards
- The practice test delivered today covers Topic 5 (preparation for Quiz 4 on Thursday)



Next steps and downloads

- Thursday October 15 (Class 16): 5.3 analysing anomalies step by step · 5.4 diagnosing and documenting · 5.5 communicating · Quiz 4
- Friday October 16 (Class 17): Topic 6 optimisation · Lab 3
- Saturday October 17: final exam review · Monday October 19: final exam (in class, 40 %)
- Downloads: both scripts, all data files, 5 figures (SVG + PNG), 17 reference tables (CSV + XLSX), this module and the hand-out
- Homework: watch the two 5.1 videos; run both scripts on your own machine



References and links (all official sites — click to open)

- [Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0](#)
- [NIST SP 800-61 Rev. 3 — Incident Response Recommendations \(2025\)](#)
- [NIST SP 800-94 — Guide to Intrusion Detection and Prevention Systems](#)
- [NIST SP 800-92 — Guide to Computer Security Log Management · NIST CSF 2.0](#)
- [Canadian Centre for Cyber Security — ITSAP.40.003 Developing your incident response plan](#)
- [FIRST — CSIRT Services Framework v2.1 \(definition of triage\)](#)
- [MITRE ATT&CK — T1046 Network Service Discovery · T1110 Brute Force](#)
- [Criminal Code of Canada s. 342.1 \(and s. 184\) · CFAA 18 U.S.C. § 1030 · Directive 2013/40/EU · Ley Orgánica 10/1995](#)
- [VirusTotal — check any link before trusting it \(Legal Notice, Annex C\)](#)
- Full list with one-line explanations in the module



Thank you — Cyber.SoHo Educational Hub



- From the Industry to the Classroom — Building the IT's Future, Today and Together !
- Educational material — Cyber.SoHo / Asen Grozdanov — © 2026 Cyber.SoHo — ALL Rights Reserved
- Governed by the Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0
- Authorised lab only · fictional data only · confidentiality of monitoring data
- Questions: MIO

